

ラボ 2.1: 外部攻撃対象領域

1. はじめに

1.1. 必要なリソース

- ノートパソコンのウェブブラウザ

1.2. 概要

このラボでは、攻撃者がリモートアクセスやインターネットに公開されているシステムを見つけるために使用するいくつかの手法について探っていきます

1.3. 目標

- Googleを使用してセキュリティ情報を特定する
- Googleを使用して、潜在的に脆弱なシステムを特定する
- Shodanを使用して潜在的に脆弱なシステムを特定する
- Shodanを使用してVPNやその他のリモートアクセスシステムを見つける

2. 脆弱性速報

ICSベンダー製品の脆弱性を特定するには、いくつかの方法があります。このラボでは、シーメンスの2つの製品を取り上げます。シーメンスを選んだ最大の理由は、同社のS7-1200 PLCが、イーサネットインターフェースを備えた市場で最も安価なPLCだからです。そのため、サイバーセキュリティ研究者によって最も多く購入され、研究されているPLCの1つでもあり、多くのCVEとエクスプロイトが利用可能です。そのため、完全にパッチが適用されていれば、おそらく最も安全なPLCの1つと言えるでしょう。;-)

ウェブブラウザを開き、Google検索ページに移動します

まず、一般的な用語を検索します。

シーメンスの脆弱性を検索

これにより、すべてのセキュリティ アドバイザリを含むページにリンクする、Siemens の脆弱性処理ページのような検索結果が表示されます。

または、より具体的な用語を Google で検索することもできます。

シーメンスのHMI脆弱性を検索

Siemens と ICS-CERT の他に、上位 20 件の結果の中にセキュリティ速報の優れたソースはありますか？

シーメンス s7-1200 の脆弱性を検索

S7-1200 にはいくつの CVE がありますか?

? 最も重大度が高い CVE はどれですか?

HMIとS7-1200 PLCには、様々な脆弱性が存在します。最も危険な脆弱性の一部を以下に示します。

- **SQLインジェクション**: 攻撃者がデータベースを読み書きしたり、システムシェルを取得したりできるようになります。
- **クロスサイトスクリプティング (XSS)**: 攻撃者がユーザーのブラウザでコードを実行できるようにする認証バイパス: 攻撃者がユーザー名やパスワードなしでログインできるようにする
- **SSL証明書の安全でない保管**: 攻撃者がサーバーからSSL証明書を盗み、それを使用してトラフィックを復号化したり、システムを複製したりすることができます。
- **SNMPのサービス拒否 (DoS)**: 攻撃者がデバイスの機能を停止できるようにする

Google のインデックスは常に変化しているため、正確な検索結果は異なる場合がありますが、それでも、これらの質問に対する潜在的な答えを多数見つけることができるはずです。

3. Googleハッキング

システムのログインページに表示される正確なキーワードがわかれば、Googleを使って、インターネットに公開されているこのソフトウェアを実行しているシステムを特定できます。例えば、ほとんどのシーメンスHMI製品では、**Simatic HMI Miniweb on** ログインページに「」が表示されます。そのため、その検索文字列を含むすべてのウェブページをGoogleで検索すると...

検索 Simatic HMI Miniweb on

警告

検索結果ページにアクセスした場合、操作権限のあるシステムでない限り、ログインしたりシステムを使用したりしないでください

Siemens HMIソフトウェアを実行しているシステムへのリンクのリストが表示されます。検索結果のすべてが、このソフトウェアを実行している実際のシステムであるわけではないことに注意してください。検索結果の中には、この種の技術の使用について解説したブログや記事、あるいは攻撃者を誘い込んで行動を追跡しようとするハニーポットなどが含まれる場合があります。いずれにせよ、これらのページにアクセスした場合は、操作権限のあるシステムでない限り、ログインしたりシステムを使用したりしないでください。明示的な許可なく最初のページを超えることは倫理的に問題となるため、一部の法域では違法となる可能性があります。

社内ネットワークでシーメンス製HMIシステムを稼働させており、インターネットに公開されている疑いがある場合は、

`site:yourcompany.com` 検索語の末尾に「」を追加することで、検索範囲を社内ドメインに限定することができます。例えば、「」を検索することで、**"Simatic HMI Miniweb on" site:doe.gov** DOE（米国エネルギー省）がシーメンス製HMIをインターネットに公開しているかどうかを確認することができます。

4. 初段

さあ、Shodanで遊んでみましょう。

⚠ Shodanへのアクセスが制限されている可能性があります

職場のコンピュータからこのツールを使用する際は注意が必要です。組織によってはShodanへのアクセスが禁止されている場合や、Shodan登録時に会社のメールアドレスの使用が制限されている場合があります。そのような場合は、上司に働きかけて、あなたとチームにShodanへのアクセスを許可してもらってください。Shodanは非常に強力なツールなので、ぜひ活用してください。

このラボに関しては、職場から Shodan にアクセスできない場合は、自宅のパソコン、またはモバイルからこのラボを実行することをお勧めします。

☰ ログインまたは無料アカウントを登録する

Shodanアカウントをお持ちでない場合は、無料アカウントを作成できます。無料アカウントがなくてもShodan検索は可能ですが、検索結果は大幅に制限されます。

[Shodanログイン](#)

[Shodan登録](#)

4.1. シーメンスHMI

検索 **siemens hmi**

✓ 成功

結果は次のようになります。

The screenshot shows the Shodan search results for the query 'siemens hmi'. The interface includes a top navigation bar with links like 'Shodan', 'Developers', 'Monitor', and 'View All...'. Below the search bar, there are tabs for 'Exploits', 'Maps', 'Share Search', 'Download Results', and 'Create Report'. The main content area displays the following information:

- TOTAL RESULTS:** 47
- TOP COUNTRIES:** A world map showing the distribution of results, with a table listing the top countries: Czechia (9), United States (6), France (5), Italy (4), and Sweden (3).
- TOP SERVICES:** A table listing the top services: SNMP (40), Siemens S7 (5), 4840 (1), and HTTPS (1).
- Search Results:** Three results are shown, each with an IP address, a company name, and a brief description of the device.
 - 179.49.3.53:** corp-179-49-3-53.ulo.puntonet.ec, Puntonet S.A., Ecuador, Quito. Description: Siemens, SIMATIC HMI, XP277, 6AV6 643-0CD01-1AX0, HW: 0, SW: V 1 1 1
 - 213.192.55.186:** Liberty Global, Added on 2020-07-21 02:43:34 GMT, Czechia, Caslav. Description: Location designation of a module: Copyright: Original Siemens Equipment. Manufacturer and profile of a CPU module: * Module type: WinAC MP 277 PLC name: SIMATIC HMI Station Module: 6ES7 671-5EP01-0YA0 v.0.4 Plant identification: Module name: WinAC MP 277 Serial number of module: Basic Firmware...
 - 87.195.254.47:** 887-195-254-047.solcon.nl, Solcon Internet. Description: Siemens, SIMATIC HMI, TP1200 Comfort, 6AV2 124-0MC01-0AX0, HW: 0, SW: V 14 0 1

Shodanはいくつかのシステムを返します。上のスクリーンショットの左側の概要統計を見ると、結果のほとんどがSNMPサービスであることがわかります

最初の結果の詳細をクリックします

✓ 成功

結果は次のようになります。

Shodan Developers Monitor View All... Show API Key Try out the new beta website! Help Center

SHODAN

Explore Downloads Reports Pricing Enterprise Access My Account

© OpenMapTiles Satellite | © MapTiler | © OpenStreetMap contributors

📍 179.49.3.53 corp-179-49-3-53.uio.puntonet.ec View Raw Data

City	Quito
Country	Ecuador
Organization	Puntonet S.A.
ISP	Puntonet S.A.
Last Update	2020-07-21T12:23:49.660546
Hostnames	corp-179-49-3-53.uio.puntonet.ec
ASN	AS22724

Ports

Port	Protocol
23	tcp
137	udp
161	udp
5800	tcp
5900	tcp

Services

Port	Protocol	Service
23	tcp	telnet
Connection failed. Windows CE Telnet Service cannot accept anymore concurrent users.		
137	udp	netbios
NetBIOS Response MAC: 00:0e:8c:a8:98:13		
161	udp	snmp
Siemens, SIMATIC HMI, XP277, 6AV6 643-0CD01-1AX0, HW: 0, SW: V 1 1 1		
5800	tcp	http-simple-new
HTTP/1.1 200 OK Connection: close		
5900	tcp	http-simple-new
VNC RFB 003.005		

© 2013-2020, All Rights Reserved - Shodan®

画像の右側に表示される結果は、Shodanがこのシステムで検出したサービスの履歴リストです。このシステムではVNC、SNMP、NetBIOSサービスが実行中であることがわかります。

Shodanで見つかったIPアドレスにアクセスする場合は、ご注意ください。悪意のある攻撃者、セキュリティ研究者、政府機関などは、脆弱なマシンに見せかけたハニーポットを設置し、訪問者の行動を攻撃したり追跡したりすることがあります。インターネット上のパブリックIPアドレスにアクセスすることは、世界中のほとんどの法域で合法ですが、そのシステムの使用許可を得ていない場合、そのサイトで何らかの操作を行うことは違法とみなされる可能性があります。

4.2. S7 1200 PLC

それでは、Shodan を使用して Siemens S7 1200 PLC を検索してみましょう。

検索 s7-1200

✓ 成功

結果は次のようになります。

The screenshot shows the Shodan search interface with the query 's7-1200'. The results page displays a total of 411 results. On the left, there are summary sections for 'TOP COUNTRIES' (listing Italy, Japan, United States, Turkey, and Israel), 'TOP SERVICES' (listing SNMP, 4840, and SMTP), and 'TOP ORGANIZATIONS' (listing Vodafone Italia, Asahi Net, Telecom Italia Mobile, Verizon Wireless, and Celcom Group). The main results list shows several entries, each with an IP address, organization name, and hardware details. For example, the first entry is 193.252.44.147, identified as Orange, located in France, Saint-Denis, with hardware: Siemens, SIMATIC S7, CPU-1200, 6ES7 212-1AE40-0XB0, HW: 7, FW: V.4.2.1, S V-K5C12141. Other entries include 121.1.172.94 (Asahi Net, Japan, Fukushima), 81.215.202.182 (Turk Telekom, Turkey, Istanbul), 203.69.248.252 (HiNet, Taiwan), and 213.6.100.164 (Palestine Telecommunications Company (PALTEL), Palestine, Bethlehem).

このような検索を行うと、そのハードウェアを実行していると主張するSNMPサービスがいくつか表示されます。Shodanで正確な検索語を見つけて探しているシステムを見つけるのは難しい場合があります。ただし、テストラボで探しているシステムやデバイスにアクセスできる場合は、Nmapを使用してオプションでポートスキャンすることができます `-sV`。これにより、Shodanで同様のデバイスを見つけるために使用できるサービスバナーの例が得られます。また、通常、Googleを使用して、ベンダーのドキュメ

ント、ブログ投稿、メーリングリスト、およびこの情報を含むことが多いその他のWebサイトを検索することで、適切な文字列を見つけるのに役立ちます

例

Shodanの検索結果を確認してください `57-1200`。バージョン番号やその他の識別子に基づいて、先ほど特定したCVEのいずれかに脆弱な可能性のあるデバイスがありますか？例えば、先ほど発見したSNMP DoS攻撃に脆弱なデバイスがありますか？

脆弱性を積極的に調査したり、疑わしい脆弱性を悪用しようとしたりすることは求められません。

4.3. リモートアクセス

それでは、インターネットに公開されているリモートアクセスサービスを探してみましょう。Shodanには、検索を絞り込むためのフィルターがいくつかあります。最も一般的なものを以下に示します

- 市
- 国
- 地理
- ホスト名
- ネット
- OS
- ポート
- 以前
- 後

これらのフィルターを使用するのはShodanの最も一般的な使用方法ですが、Shodanのアカウントを作成している必要があります。たとえば、これらのフィルターを使用して、会社またはクライアントの会社でインターネットに公開されているリモートアクセスポートとVPNポートを検索できます。最も一般的なリモートアクセスプロトコルとVPNプロトコル、およびそれらのサービスがリッスンするポートのリストを以下に示します

ポート	説明
22	セキュアシェル (SSH)
23	Telnet
500	IPSecインターネット鍵交換 (IKE)
1194	OpenVPN
1701	レイヤー2トンネリングプロトコル (L2TP) VPN
1723	ポイントツーポイントトンネリングプロトコル (PPTP)
3389	Microsoft Windows リモートデスクトッププロトコル (RDP)

ポート	説明
4500	IPSec NATトラバーサル - RFC 3947

Shodanアカウントを作成した場合（または既にお持ちの場合）、`port:22,23,500,1194,1701,1723,3389,4500`

会社のパブリック IP アドレスがわかっている場合は、`net:`または`ip:`フィルターを使用してそれらを検索文字列に追加できます。

✓ 成功

The screenshot shows the Shodan search engine interface. The search bar contains the query `port:22,23,500,1194,1701,1723,3389,4500`. The results page displays a total of 40,364,624 results. The top countries are listed as United States (11,10...), China (5,995...), Germany (2,230...), Japan (1,968...), and United Kingdom (1,631...). The top services are listed as SSH (20,49...), Telnet (5,147...), RDP (4,732...), PPTP (4,551...), and IKE (4,456...). Two specific results are highlighted:

- 182.160.101.190**: 182-160-101-190.aamranetworks.com, aamra networks limited, Added on 2020-07-21 13:26:07 GMT, Bangladesh, Dhaka. Services: vpn.
- 113.194.144.103**: 103.144.194.113.adsl-pool.jx.chinaunicom.com, China Unicom Liaoning, Added on 2020-07-21 13:26:07 GMT, China. Services: vpn.

Additional details for the second result include: Firmware: 1, Hostname: Narail Express, Vendor: MikroTik, and VPN (IKE) configuration details.

5. ボーナスチャレンジ

他の参加者がラボを完了するのを待っている場合、またはこのラボで紹介された概念をさらに深く探求したい場合は、いくつかのアイデアを試してみてください。これらのチャレンジにはチュートリアルは提供されていませんが、行き詰まった場合は、コース作成者のJustinに取り組みの過程を見せいただければ、喜んでヒントをくれるでしょう。justin_@controlthings.ioまでメールで問い合わせください

過去に使用したことがある ICS 製品 (または聞いたことがある製品) をいくつか選択し、Google と Shodan を使用して公開されているシステムを探します。

アイデアが足りない場合は、Shodan の ICS ホームページにアクセスしてみてください。

[Shodan ICSページ](#)

または、以下のメーカーをお試しください。

- ABB
- エマソン (DeltaV)
- ハネウェル
- インベンシス (現在はシュナイダーエレクトリックの一部ですが、デバイスの出力には引き続き表示されます)
- ロックウェル・オートメーション
- シュナイダーエレクトリック (Citect)